



Instituto Tecnológico y de Estudios Superiores de Monterrey

Escuela de Ingeniería y Ciencias

Ingeniería en Ciencias de Datos y Matemáticas

Uso de Álgebras Modernas para Seguridad y Criptografía

Etapas 1 del reto: Gestor de Identidades

Reporte Ejecutivo

Nombre	Matrícula
Jose Alejandro Rojas Castro	A00839067
Arturo Camacho Apolonio	A00838446
Luis Eduardo Martinez	A00840037
Daniel Emilio De Pool Oliver	A00839312
David Aguirre Ortiz de Montellano	A00839482

Equipo: Equipo 5 **Grupo:** MA2006B

Profesores: Alberto F. Martínez, Raúl Gómez, y Anas Wajid

Socio Formador: Casa Monarca, Ayuda Humanitaria al Migrante, A.B.P.

1. Resumen Ejecutivo

Casa Monarca resguarda expedientes de personas migrantes en situación de alta vulnerabilidad. El sistema de registro previo carecía de controles de acceso y almacenaba datos personales en texto plano, exponiendo información sensible ante cualquier acceso no autorizado a la base de datos.

El objetivo fue desarrollar una aplicación web que implementara primitivas criptográficas reales para garantizar confidencialidad, integridad, autenticidad y no repudio sobre los expedientes gestionados por la organización.

Se entregó una plataforma Django con cifrado híbrido RSA-4096 + AES-256-EAX, control de acceso criptográfico por roles (Zero-Trust RBAC), certificados digitales X.509 con cadena de confianza Admin → Coordinador, firma digital estilo SAT y bitácora de auditoría encadenada con SHA-256.

El impacto principal es que ningún dato de migrante es legible en reposo, en caso de querer llevar a cabo la suplantación de identidad requiere posesión física del archivo .key, y cualquier manipulación retroactiva de la auditoría es matemáticamente detectable en el sistema. Actualmente el proyecto se encuentra en fase piloto, listo para pruebas con usuarios reales y escalamiento al entorno de producción de Casa Monarca.

2. Objetivos vs Resultados

2.1 Qué se cumplió

A continuación se muestra una tabla que resalta los objetivos cumplidos durante la elaboración del gestor de identidades:

Objetivo	Estado
Cifrado de expedientes en reposo	Cumplido
Autenticación por contraseña segura (Scrypt)	Cumplido
Certificados digitales X.509 reales	Cumplido
Control de acceso basado en roles (RBAC)	Cumplido
Bitácora de auditoría inmutable	Cumplido
Firma digital de expedientes	Cumplido
Panel de administración con visibilidad criptográfica	Cumplido
Jerarquía de confianza Admin → Coordinador	Cumplido

Cuadro 1: Objetivos vs Resultados

2.2 Qué se modificó o adaptó

Algunos objetivos evolucionaron durante el desarrollo al encontrarse limitaciones técnicas o requerimientos adicionales:

Aspecto	Diseño Inicial	Evolución Final
Llaves de firma	Una sola llave RSA por usuario	Doble llave: login + firma SAT
Desbloqueo de sesión	Paso manual intermedio requerido	Integrado directamente en el login
Roles del sistema	2 roles (Admin / Voluntario)	8 roles con llaves RSA independientes

Cuadro 2: Modificaciones y adaptaciones respecto al diseño inicial

3. Solución Implementada

3.1 Qué hace la aplicación

La plataforma permite a Casa Monarca registrar, custodiar y consultar expedientes de personas migrantes atendidas, bajo las siguientes garantías criptográficas:

- **Confidencialidad total en reposo.** Cada expediente se cifra con una llave AES-256 generada aleatoriamente en RAM, cifrada con RSA-4096 para cada rol autorizado y descartada de memoria.
- **Control de acceso criptográfico.** Un usuario solo puede leer los expedientes para los cuales exista un registro de acceso con su llave pública. El rol en base de datos no es suficiente; el sistema exige que la llave privada del rol haya sido descifrada correctamente en sesión (Zero-Trust RBAC).
- **Integridad verificable.** Cada expediente almacena un hash SHA-256 de su criptograma. Cualquier modificación no autorizada altera el hash y es detectable.
- **No repudio.** Los coordinadores y administradores firman digitalmente los expedientes con su llave de firma RSA-4096 personal, verificable con su certificado X.509 público.
- **Auditoría forense.** Cada acción genera un evento en la bitácora encadenada con SHA-256, de forma que cualquier eliminación o edición retroactiva es detectable al recalcular la cadena.

3.2 Usuarios e impacto generado

El sistema cuenta con 8 roles organizados en una jerarquía de confianza, cada uno con llaves RSA independientes. El Administrador tiene control total (CRUD) y opera con un certificado X.509 auto-firmado más llave de firma tipo SAT. Los cinco roles de Coordinador (Administración, Legal, Psicosocial, Humanitario y Comunicación) tienen permisos CRU y operan con certificado firmado por el Administrador más llave de firma tipo SAT. Los roles Operativo (CR) y Usuario (C) utilizan únicamente llave de login para acceso básico al sistema.

3.3 Alcance final

La solución entregada cubre los siguientes módulos y capacidades:

- Gestión completa de expedientes cifrados (alta, lectura, edición, eliminación, firma y verificación).
- Gestión del ciclo de vida de identidades (creación, regeneración y revocación por expiración de certificado).
- Panel de administración con visibilidad del estado criptográfico de cada usuario.

- Distribución automatizada de llaves de rol a usuarios entrantes.
- Comando de rescate `regenerar_admin` para recuperación de acceso sin necesidad de HTTP.

4. Impacto de Negocio

4.1 Métricas antes vs después

Dimensión	Antes	Después
Datos en BD accesibles para DBA malicioso	Sí	No — AES-256
Llave privada accesible sin contraseña	Sí	No — doble cifrado
Verificación de autoría de expedientes	Ninguna	Firma RSA-4096
Detección de manipulación de bitácora	Imposible	Hash SHA-256 encadenado
Granularidad de control de acceso	2 roles	8 roles + llave por rol
Expiración y revocación de identidades	No existe	Certificado X.509 — 1 año
Evidencia forense de operaciones	Log básico	Bitácora blockchain
Sesión comprometida expone datos futuros	Sí	No — llaves en RAM, no BD

Cuadro 3: Comparativa de seguridad antes y después de la solución

4.2 Reducción de riesgos

La arquitectura criptográfica implementada mitiga de forma directa las principales rutas de ataque a los que Casa Monarca estaba expuesta. Una brecha de base de datos solo expone criptogramas, hashes y llaves cifradas — ningún dato de migrante es recuperable sin las llaves privadas de los usuarios. La suplantación de identidad es imposible sin el archivo `.key` físico del usuario y su contraseña de 64 caracteres. Cualquier intento de manipulación de la auditoría es detectable matemáticamente al recalcular la cadena SHA-256 de la bitácora. Finalmente, la escalación de privilegios queda neutralizada: un usuario con rol manipulado en la base de datos no puede descifrar expedientes si no posee la llave privada del rol objetivo.

4.3 Productividad y eficiencia

La solución no solo fortalece la seguridad, sino que optimiza la operación diaria de Casa Monarca. El desbloqueo de sesión ocurre una sola vez al iniciar sesión, sin interrupciones al consultar expedientes. La distribución de llaves de rol a nuevos usuarios es totalmente automatizada, eliminando configuraciones manuales. El panel de administración permite monitorear el estado criptográfico de todos los usuarios en una sola pantalla, y el comando `regenerar_admin` permite recuperar acceso en minutos ante una emergencia, sin intervención de base de datos manual.

5. Lecciones y Hallazgos

5.1 Qué funcionó bien

- **Cifrado híbrido RSA + AES:** Demostró ser la combinación correcta. AES para el volumen de datos y RSA para distribuir el acceso. El modelo *AccesoExpediente* con multi-copia de la llave AES resultó elegante y funcional.
- **Separación llave de login / llave de firma:** Siguiendo el modelo del SAT mexicano, se generó una separación clara entre identidad operativa y autorización de transacciones críticas, siendo una lógica fácil de entender para usuarios no técnicos.
- **Middleware de expiración de certificados:** El bloqueo automático de sesión ante certificados vencidos se convirtió en una capa de defensa pasiva robusta sin requerir esfuerzo adicional por parte del administrador.

5.2 Qué se puede mejorar

- **Gestión de SECRET KEY:** Actualmente la rotación implica re-cifrado manual de todos los Encrypted-TextField. Debería automatizarse con un procedimiento de migración de llave.
- **Recuperación ante pérdida de .key:** el modelo actual no tiene mecanismo de recuperación del archivo de firma. Implementar un esquema de custodia con umbral (Shamir Secret Sharing) daría resiliencia operativa.

5.3 Riesgos detectados

Riesgo	Mitigación
Compromiso de SECRET_KEY Django	Rotación urgente + re-cifrado de BD
Expiración masiva sincronizada de certificados	Monitoreo en panel + alertas tempranas
Sesiones largas exponen llaves en RAM	Timeout de sesión configurable

6. Estado Actual y Próximos Pasos

6.1 Estado del proyecto

El proyecto se encuentra en una fase piloto completamente funcional y desplegada, habiendo concluido la transición de un sistema vulnerable a una arquitectura de seguridad basada en un modelo Zero-Trust. El estado de sus componentes principales se detalla a continuación:

- **Backend:** La solución está desarrollada sobre el framework Django. Implementa un middleware de seguridad encargado de la expiración automática de sesiones al detectar certificados vencidos y gestiona de forma automatizada la distribución de llaves de rol a usuarios entrantes. Además, cuenta con un comando de rescate fuera de banda (`regenerar_admin`) para la recuperación del acceso en contingencias.

- **Autenticación y Control de Acceso (RBAC):** Se migró de un esquema básico a un sistema de control de acceso criptográfico basado en 8 roles con llaves RSA independientes. La autenticación de contraseñas seguras se realiza mediante el algoritmo de derivación de claves Scrypt. El desbloqueo de la sesión se integra directamente en el login, cargando en la memoria RAM del servidor las llaves privadas del rol descifradas (las llaves se descartan de la memoria al finalizar la sesión y nunca se almacenan en texto plano).
- **Certificados e Identidades Digitales:** Se ha desplegado una infraestructura de clave pública (PKI) interna con certificados digitales X.509 reales y una vigencia de 1 año. Existe una jerarquía de confianza donde el Administrador (con certificado autofirmado) firma los certificados de los 5 roles de Coordinador. Adicionalmente, se implementó un esquema de doble llave (estilo SAT) que separa la identidad operativa (llave de login) de la autorización de transacciones críticas (llave de firma RSA-2048).
- **Base de Datos (BD):** Los datos en reposo están completamente protegidos contra administradores de bases de datos (DBA) maliciosos o filtraciones. Cada expediente guardado en las tablas correspondientes se encuentra bajo un esquema de cifrado híbrido, utilizando un criptograma AES-256-EAX (con una llave aleatoria por expediente) y el hash SHA-256 de dicho criptograma para verificar su integridad. Las llaves AES se almacenan protegidas mediante envoltura con la llave pública RSA-2048 de cada rol autorizado a través del modelo `AccesoExpediente`.

6.2 Recomendaciones

Para evolucionar la plataforma de la fase piloto hacia un entorno de producción masivo y resiliente en Casa Monarca, se definen las siguientes acciones prioritarias:

1. **Esquema Resiliente de Backups y Recuperación de Llaves:** Debido a que el modelo actual carece de un mecanismo de recuperación ante la pérdida del archivo físico de firma (`.key`), se requiere diseñar e integrar un sistema de respaldo basado en el esquema de custodia con umbral de *Shamir* (*Shamir's Secret Sharing*). Esto permitirá fragmentar las llaves críticas de la organización y distribuirlas entre custodios designados, garantizando la resiliencia operativa sin centralizar el secreto ni vulnerar la filosofía Zero-Trust.
2. **Robustecimiento y Monitoreo de la Bitácora de Auditoría:** Si bien se cuenta con una bitácora forense inmutable basada en el encadenamiento de hashes *SHA-256* (estructura tipo **blockchain**), el siguiente paso es automatizar el proceso de verificación. Se implementará un servicio de monitoreo en segundo plano que recalcule e inspeccione de forma síncrona/asíncrona la integridad de la cadena de bloques de la bitácora. Ante cualquier discrepancia matemática provocada por intentos de borrado o edición retroactiva de eventos, el sistema disparará alertas inmediatas en el panel de administración.